

Introdução a Auditoria de Sistemas

Resumo Executivo Focado

A rápida transformação digital e a consolidação dos ambientes computacionais híbridos impuseram uma reestruturação profunda nas metodologias de governança e controle corporativo¹. A auditoria de sistemas de informação surge como uma disciplina crítica para avaliar se a infraestrutura tecnológica e as aplicações de software atendem aos princípios de segurança, integridade, confidencialidade e disponibilidade, protegendo os ativos organizacionais contra vulnerabilidades crescentes¹.

Este relatório analisa a auditoria de sistemas de TI sob a ótica de sua evolução histórica e de seus conceitos fundamentais, confronta as abordagens interna e externa, detalha as distinções entre controles gerais e de aplicação, e mapeia os principais frameworks globais de controle⁴. Adicionalmente, desmistifica-se a relação intrínseca da auditoria com o Ciclo de Vida de Desenvolvimento de Software (SDLC)⁷. Por fim, são expostos cenários práticos e apresentadas de forma estruturada as fontes normativas que fundamentam o exercício ético e profissional desta atividade de controle³.

Evolução Histórica e Conceito de Auditoria de Sistemas

Embora a auditoria seja reconhecida hoje por seu alto teor tecnológico, suas raízes históricas remontam a mais de 5.000 anos antes de Cristo, com manifestações rudimentares de controle de produções agrícolas, tesouros reais e arrecadação de tributos no Egito e na Suméria¹¹. O termo "auditor" (do latim *audire*, aquele que ouve) foi formalizado no século XIII, quando o rei Eduardo I designou um funcionário para examinar as contas de sua falecida esposa, consolidando a natureza contábil e fiscal da profissão¹¹. Com o advento do processamento eletrônico de dados no século XX, as trilhas físicas de papel foram substituídas por registros intangíveis, forçando a reformulação da disciplina para o que hoje se denomina Auditoria de Tecnologia da Informação¹.

De acordo com as definições consolidadas pelo Guia de Auditoria de TI da Organização Internacional das Entidades de Fiscalização Superiores (INTOSAI), a auditoria de TI compreende um exame e revisão sistemática de sistemas de informação e de seus controles relacionados¹. Esse processo visa obter segurança razoável e atestar a conformidade das ferramentas tecnológicas com as reais necessidades organizacionais, impedindo o comprometimento da privacidade, segurança e eficiência de custos¹. Sob a perspectiva operacional descrita na literatura, a auditoria de sistemas de informação atua na revisão e avaliação contínua dos controles lógicos, infraestrutura física, operações de dados, desempenho de servidores e procedimentos de segurança que suportam as decisões estratégicas do negócio³. No contexto nacional, o Tribunal de Contas da União (TCU) consolidou ampla jurisprudência subordinando a

segurança da informação à governança geral de TI, reforçando a auditoria de sistemas como instrumento indispensável de controle externo¹².

A necessidade de auditoria de sistemas manifesta-se de forma crítica em pequenas e médias empresas (PMEs), que frequentemente subestimam os riscos associados à conexão com redes globais e desconhecem o valor real dos dados que armazenam². O fator humano emerge como o elemento de maior vulnerabilidade nessas estruturas; investimentos em segurança tecnológica tornam-se ineficazes se os colaboradores não forem continuamente treinados e conscientizados a respeito de ameaças como a engenharia social, técnica na qual criminosos utilizam a persuasão e a manipulação psicológica para contornar controles lógicos corporativos¹³. Assim, a auditoria de sistemas deve transcender a análise de códigos e hardwares, avaliando também a eficácia dos programas de treinamento em segurança da informação¹³.

Diferenciação entre Auditoria Interna e Externa de TI

As auditorias de sistemas subdividem-se em duas categorias complementares, cujos propósitos e públicos-alvo operam em dimensões distintas do controle corporativo⁴. A auditoria interna de TI foca na melhoria contínua dos controles internos, gestão de riscos e processos operacionais, servindo como uma ferramenta estratégica preventiva para a alta administração e colaboradores⁴. Conduzida por profissionais da própria empresa ou consultores contratados, ela goza de maior flexibilidade de cronograma e deve ser realizada preferencialmente de forma anual, antecipando-se à auditoria externa⁴. O seu escopo técnico é balizado por padrões como a NBC TI 01 e as diretrizes internacionais do Institute of Internal Auditors (IIA), cobrindo auditorias operacionais, administrativas, de conformidade e de sistemas³.

Em contrapartida, a auditoria externa (ou independente) visa conferir transparência, credibilidade e fé pública às demonstrações contábeis e à robustez dos controles que suportam as transações financeiras⁴. Regulada pela NBC TA 200, pelas normas do PCAOB e do AICPA, ela é executada por terceiros totalmente independentes e sem vínculo com a organização³. Suas conclusões destinam-se tanto à governança interna quanto a stakeholders externos, como investidores, acionistas, credores e agências reguladoras que exigem atestações de conformidade⁴.

Elemento de Diferenciação	Auditoria Interna de TI	Auditoria Externa de TI
Vínculo Profissional	Colaborador direto da empresa ou consultor sob a gestão interna ⁴ .	Profissional independente, sem qualquer vínculo com a organização ⁴ .
Objetivo Principal	Avaliar processos, mitigar riscos operacionais e	Emitir parecer independente sobre a

	educar a direção e colaboradores ⁴ .	fidedignidade de registros e conformidade regulatória ⁴ .
Público-Alvo	Diretoria Executiva, Conselho de Administração e Comitê de Auditoria Interna ⁴ .	Investidores, acionistas, órgãos reguladores, clientes e fornecedores ⁴ .
Periodicidade e Flexibilidade	Atividade contínua, com alta flexibilidade para ajustar cronogramas e escopos ⁴ .	Atividade periódica (geralmente anual), associada ao encerramento de exercícios fiscais ⁴ .
Padrões Normativos	NBC TI 01 (Brasil) e estrutura IPPF do Institute of Internal Auditors (IIA) ³ .	NBC TA 200 (R1), padrões PCAOB e atestações AICPA (SOC 1, 2, 3) ³ .

Especificidades de TI e Estrutura de Controles de TI

A auditoria de TI baseia-se na avaliação detalhada de duas classes fundamentais de controles: os Controles Gerais de TI (ITGC - *IT General Controls*) e os Controles de Aplicação (ITAC - *IT Application Controls*)¹. Para estabelecer o escopo dessa avaliação de maneira eficiente, os auditores utilizam metodologias como a GAIT (Guide for Assessment of IT Risks), que propõe uma abordagem de risco de cima para baixo (*top-down*) para identificar deficiências nos ITGCs que possam impactar diretamente a integridade dos relatórios financeiros¹⁶. Adicionalmente, as organizações podem implementar a Autoavaliação de Controles (CSA - *Control Self-Assessment*), técnica que extrai o conhecimento prático dos colaboradores que vivenciam os processos diariamente para acelerar a identificação de gaps, embora sem substituir o exame independente executado pela auditoria interna¹⁶.

Categoria de Controle	Escopo de Atuação	Exemplos de Controles e Procedimentos de Auditoria
Controles Gerais de TI (ITGC)	Infraestrutura ampla de TI, garantindo a estabilidade e segurança lógica e física do ambiente de dados ¹ .	- Segurança Física: Controle de acesso biométrico e monitoramento por CFTV em data centers¹. - Segurança Lógica:

		Gestão de identidades, uso de senhas fortes e MFA¹⁵. - Gestão de Mudanças: Processo de aprovação formal para alterações de programas em produção¹. - Backup e Recuperação: Rotinas de cópias de segurança de dados e planos de continuidade de negócios¹.
Controles de Aplicação (ITAC)	Transações lógicas específicas embutidas em sistemas de software individuais ¹ .	- Validação de Entrada: Máscaras de dados e validação de dados de entrada para impedir injeções de código¹. - Controle de Processamento: Validação lógica interna, conciliação de totais e integridade transacional¹. - Validação de Saída: Rastreamento de logs de exportação de dados e relatórios de validação de saídas¹.

Modelos Globais de Governança e Segurança

A análise da maturidade dos controles de TI requer o alinhamento com frameworks internacionais reconhecidos⁴. O COBIT 2019, desenvolvido pela ISACA, representa a estrutura de governança mais abrangente do mercado, diferenciando de maneira categórica os sistemas de governança (responsáveis por avaliar, dirigir e monitorar os objetivos estratégicos através do domínio EDM) dos sistemas de gestão (focados no planejamento, construção, entrega e monitoramento operacional através dos domínios APO, BAI, DSS e MEA)⁶. O COBIT aborda cinco áreas de foco fundamentais: o alinhamento estratégico, a entrega de valor, a gestão de recursos (como aplicativos e informações), o gerenciamento de risco e a medição de

desempenho¹⁸. Em sua versão 2019, o framework adotou um modelo de atualização contínua colaborativo (*open-source*), maior flexibilidade para aplicação em projetos específicos e um forte foco na capacitação profissional²⁰.

A ISO/IEC 27001:2022 atua como o escudo de segurança da informação da organização, definindo as especificações para o estabelecimento de um Sistema de Gestão de Segurança da Informação (SGSI) baseado na tríade de confidencialidade, integridade e disponibilidade¹⁹. A norma organiza seus controles em domínios estruturados, incluindo políticas de segurança, segurança de recursos humanos, gestão de ativos, controle de acesso físico e lógico, criptografia e segurança operacional¹⁷. A sinergia entre o COBIT 2019 e a ISO 27001 ocorre por meio do mapeamento de seus processos, permitindo que o ciclo Plan-Do-Check-Act (PDCA) da ISO forneça as especificações técnicas de segurança exigidas pelas diretrizes estratégicas do COBIT⁶.

Adicionalmente, o NIST Cybersecurity Framework provê uma abordagem prática para a resiliência cibernética, estruturada em cinco pilares fundamentais: Identificar, Proteger, Detectar, Responder e Recuperar¹⁹. Embora o NIST seja amplamente adotado, ele pode representar uma sobrecarga operacional desnecessária para empresas de pequeno porte devido ao rigor e à complexidade de seus requisitos, tornando a ISO 27001 uma opção inicial mais escalável¹⁹. Por fim, o ITIL complementa esse ecossistema ao ditar as melhores práticas operacionais para a entrega de serviços de TI, organizando o suporte diário e a transição de serviços de forma alinhada às expectativas da governança de TI²¹.

O Papel Estratégico do Auditor de Sistemas de TI

O papel do auditor transcende a mera verificação de conformidade; ele atua como um parceiro estratégico que assessora os gestores de TI e a alta liderança na governança e na gestão dos recursos tecnológicos, avaliando se a alocação de investimentos reflete a estratégia corporativa²². Para garantir a qualidade e padronização de suas atividades, o auditor deve fundamentar seu trabalho em diretrizes profissionais emitidas por organizações internacionais de controle, como o ITAF da ISACA, a norma de planejamento integrado AS 2101 do PCAOB, as seções de auditoria do AICPA (como a AU-C 300) e o IPPF do IIA³. No campo comportamental, o auditor de sistemas de informação deve pautar-se nas sete diretrizes do Código de Ética Profissional da ISACA, descritas a seguir³:

1. **Apoio aos Padrões:** Incentivar o cumprimento das normas, procedimentos e padrões recomendados de controle de sistemas de informação²⁴.
2. **Objetividade e Diligência:** Executar as atividades com isenção de ânimo, aplicando o ceticismo profissional e o devido zelo técnico⁵.
3. **Conduta Ética e Honestidade:** Atuar em estrita conformidade com as leis vigentes e as normas de boa-fé, preservando o prestígio da profissão²⁴.
4. **Confidencialidade e Privacidade:** Proteger o sigilo das informações coletadas durante suas análises, não as utilizando para benefício pessoal³.
5. **Manutenção da Competência:** Manter-se em constante atualização profissional, executando apenas tarefas para as quais possui habilitação técnica²⁴.

6. **Transparência no Reporte:** Reportar de forma clara e objetiva todos os achados de auditoria e fatos significativos identificados²⁴.
7. **Promoção da Conscientização:** Auxiliar os stakeholders no entendimento e difusão das melhores práticas de segurança e controle de sistemas²⁴.

Auditoria no Ciclo de Vida de Desenvolvimento de Software (SDLC)

O Ciclo de Vida de Desenvolvimento de Software (SDLC - *Software Development Life Cycle*) compreende a metodologia sistemática e iterativa que divide a criação de software em fases interdependentes⁸. Embora o SDLC assemelhe-se ao gerenciamento de ciclo de vida de aplicações (ALM - *Application Lifecycle Management*), ele se distingue por ser um subconjunto deste último, concentrando seu foco na fase de engenharia de aplicações individuais, enquanto o ALM adota uma visão corporativa ampla sobre todo o portfólio de sistemas da organização⁷. Com a transição acelerada das equipes para o DevSecOps, a segurança passou a ser embutida de forma contínua em todo o ciclo de desenvolvimento por meio de um processo de reforço denominado Secure SDLC (SSDLC)⁸. Esse modelo de desenvolvimento seguro aplica-se tanto a projetos de codificação tradicional quanto a cargas de trabalho modernas de baixo código (*low-code/no-code*), como aplicações de tela e fluxos de automação, garantindo que mesmo elementos visuais e plugins estejam livres de falhas lógicas e em total conformidade com os requisitos de controle⁸.

[Fase 1: Planejamento] ---> Checkpoint: Análise de custo-benefício e viabilidade estratégica²⁸. | [Fase 2: Requisitos] ---> Checkpoint: Definição de requisitos de segurança e modelagem de ameaças⁸. | [Fase 3: Projeto] ---> Checkpoint: Desenho de controle de acesso (SoD) e arquitetura criptográfica⁷. | [Fase 4: Codificação] ---> Checkpoint: Revisão de código seguro (SAST) e gestão de dependências⁸. | [Fase 5: Testes] ---> Checkpoint: Testes de invasão (DAST) e aceitação de sistemas (10.3.2)¹⁸. | [Fase 6: Implantação] ---> Checkpoint: Gestão de mudanças corporativas e assinatura de artefatos¹. | [Fase 7: Manutenção] ---> Checkpoint: Auditoria contínua de logs (SIEM), patches e plano de continuidade¹.

A auditoria desempenha um papel crítico em cada marco do SDLC para verificar a eficácia dos seguintes controles organizacionais:

- **Aceitação de Sistemas:** Baseado em requisitos específicos de governança (como a seção 10.3.2), o auditor avalia se o sistema cumpre os critérios formais de validação operacional e testes de homologação antes de receber a autorização de transferência para produção¹⁸.
- **Segregação de Funções (SoD):** O auditor deve testar rigorosamente se há uma separação funcional efetiva e restrições lógicas que impeçam que os desenvolvedores responsáveis pela escrita ou alteração do código (manipuladores de ativos) tenham privilégios lógicos para aprovar e implantar o software em produção, mitigando o risco de sabotagem ou introdução intencional de vulnerabilidades¹.
- **Segurança no Tratamento e Descarte de Mídias:** A conformidade exige a validação de procedimentos para o descarte seguro de dispositivos de armazenamento que

contiveram dados de teste ou de produção ao longo do ciclo de vida¹⁷. Os controles determinam que as mídias sejam fisicamente destruídas, trituradas ou desmagnetizadas, sendo obrigatória a segregação de funções entre o criador do ativo e a equipe de destruição, a guarda segura em contêineres trancados e a emissão de um Certificado de Destruição (CoD) em até 30 dias¹⁷.

- **Gestão de Mudanças e Operações de Computadores:** Avaliação de rotinas de backup, testes de restauração de dados e a integração do software com o Planejamento de Continuidade de Negócios (PCN)¹. Um plano de continuidade efetivo é avaliado pelo auditor com base em suas fases de conformidade: estabelecimento de políticas, definição da função de continuidade, elaboração da Análise de Impacto ao Negócio (BIA) e teste periódico de controles preventivos¹.

Estudo de Casos Práticos e Lições de Controle

Caso 1: Fraude Transacional por Manipulação de Notas Fiscais e a Transição para IA

Em um caso emblemático de fraude corporativa corporificada no cenário tributário brasileiro, o gerente financeiro de uma rede varejista adulterou intencionalmente o valor e o registro de notas fiscais de venda diretamente nos bancos de dados para sonegar o pagamento de ICMS⁹. Sob a ótica da auditoria interna e da norma NBC TI, a ação configurou-se como fraude (distorção intencional de registros para ganho ilícito) e não como mero erro operacional, demonstrando falhas nos controles internos de processamento de dados⁹.

A investigação desse tipo de fraude em larga escala evidencia as limitações dos sistemas de monitoramento tradicionais (SIEM) baseados em regras estáticas de controle³³. Hackers e fraudadores internos refinam continuamente suas táticas para contornar limites preestabelecidos, visando principalmente contas com credenciais administrativas para apagar trilhas de auditoria³³. Diante de volumes massivos de transações cotidianas, a detecção manual ou baseada em limites fixos torna-se ineficaz³³.

A implementação de soluções de inteligência artificial (IA) dotadas de aprendizado adaptativo transforma a eficácia da auditoria de sistemas³³. Diferentemente das regras fixas, os modelos de IA analisam continuamente padrões comportamentais de contas privilegiadas e transações de alto risco, reduzindo falsos positivos e permitindo que os auditores foquem em desvios reais³³. Esse recurso é crucial para operações multinacionais, nas quais as fraudes de pagamento variam geograficamente: transações de cartão de crédito predominam nos EUA, pagamentos móveis lideram na China e transações em espécie dominam no Leste Europeu³³. O aprendizado adaptativo ajusta os limites de detecção para cada contexto geográfico, assegurando a precisão do controle³³.

Caso 2: Incidentes de Acesso e Riscos de Conformidade com a LGPD

Em outro cenário de controle de logs, uma empresa de tecnologia identificou falhas graves de rastreabilidade devido à desorganização e fragmentação de seus registros de sistema¹⁰.

Eventos locais de servidores, logs de conexões externas de firewalls e acessos a dados em suítes de produtividade na nuvem estavam espalhados em repositórios desvinculados, impossibilitando uma visão consolidada¹⁰. A falta de um inventário de hardware atualizado permitiu que dispositivos não autorizados se conectassem à rede sem o cruzamento de logs correspondentes¹⁰.

Esse cenário gera uma exposição crítica perante a Lei Geral de Proteção de Dados (LGPD), que impõe a obrigação de demonstrar de forma clara quem acessou dados pessoais, quando e com qual finalidade regulamentar¹⁰. A lição aprendida forçou a empresa a reestruturar seus processos, centralizando os registros em um repositório imutável e estabelecendo controles rígidos de segurança lógica para validação contínua de acessos a dados sensíveis corporativos¹⁰.

Detalhamento das Fontes de Pesquisa e Normativos de Referência

Abaixo estão relacionadas as principais referências normativas e bibliográficas utilizadas para estruturar as metodologias de auditoria de sistemas descritas neste documento.

Código / Referência	Título / Origem	Escopo Principal na Auditoria	Aplicabilidade Prática
INTOSAI (2013)	Guia de Auditoria de TI ¹	Definições e diretrizes de auditoria governamental de sistemas de informação ¹ .	Exame de conformidade e detecção de quebras de princípios de integridade e segurança ¹ .
NBC TI 01 / NBC TA 200	Conselho Federal de Contabilidade ⁵	Normas Brasileiras de Contabilidade para Auditoria Interna e Externa ⁵ .	Definição de responsabilidades, independência e formato de pareceres profissionais ⁵ .
ITAF (ISACA)	IT Assurance Framework [cite: 3]	Padrões obrigatórios e guias para o exercício técnico da auditoria de sistemas ³ .	Planejamento, execução de testes lógicos e geração de relatórios de conformidade de TI ³ .

COBIT 2019	ISACA / ITGI ⁶	Modelo de governança corporativa de TI focado em valor e gestão de recursos ⁶ .	Alinhamento estratégico e estruturação de domínios de controle (EDM, APO, BAI, DSS, MEA) ⁶ .
ISO/IEC 27001:2022	ISO / ABNT ²	Padrão global para implementação de SGSI e controles gerais de segurança ¹⁹ .	Auditoria de segurança de rede, criptografia, controle de acessos lógicos e descarte de mídias ¹⁷ .
Resolução TCE-RO 245/2017	Tribunal de Contas de Rondônia ¹⁸	Diretrizes de auditoria de governança de TI e controles de aplicação ¹⁸ .	Verificação de aceitação de sistemas e validação lógica de entradas, processamentos e saídas ¹⁸ .
Manoel, S. S. (2014)	Governança de Segurança da Informação (Braspot) ¹³	Mitigação de vulnerabilidades com foco em engenharia social e treinamento de pessoal ¹³ .	Avaliação de eficácia de controles humanos e campanhas de conscientização interna ¹³ .

Conclusões e Recomendações Estruturadas

A evolução da auditoria de sistemas de informação consolida sua posição como um instrumento indispensável de governança, blindagem operacional e garantia de conformidade legal¹. As organizações não podem mais tratar a tecnologia como um departamento isolado; ela constitui o próprio motor transacional que viabiliza a geração de valor e a relação de confiança com clientes e parceiros de negócios¹⁸. O controle contínuo sobre o ecossistema tecnológico protege as marcas contra vazamentos catastróficos e sanções regulatórias¹⁰. Diante do exposto nesta análise detalhada, recomendam-se as seguintes ações estruturadas para o aprimoramento do ambiente de controle das organizações:

- **Integração Mandatória do Modelo SSDLC:** Substituir os ciclos de auditoria retrospectivos por revisões de segurança preventivas integradas diretamente à esteira de desenvolvimento de software⁸. A verificação automatizada de dependências e a

realização de testes de segurança estática (SAST) e dinâmica (DAST) em tempo de compilação devem constituir requisitos de homologação obrigatórios de novos sistemas⁸.

- **Implementação Rigorosa de Segregação de Funções (SoD):** Revisar as matrizes de acesso lógico de todos os colaboradores, garantindo que profissionais das equipes de engenharia de software não detenham permissões para implantar artefatos de código diretamente nos servidores de produção¹.
- **Modernização do Monitoramento de Logs com IA Adaptativa:** Superar os limites das ferramentas de detecção baseadas em limites estáticos através da implementação de soluções de inteligência artificial com aprendizado adaptativo, centralizando os logs das aplicações híbridas em ambientes SIEM para identificação ágil de transações suspeitas e incidentes de segurança¹⁰.
- **Fortalecimento das Campanhas de Conscientização Humana:** Estabelecer programas de treinamento recorrentes focados na identificação de golpes de engenharia social, reconhecendo que a segurança da informação depende diretamente da maturidade comportamental dos usuários de sistemas e colaboradores¹³.

Referências citadas

1. manual de auditoria de tecnologia da informação - TCE-AM, <https://www.tceam.tc.br/wp-content/uploads/2020/08/4-Portal-SECEX-Manual-de-Auditoria-Tecnologia-da-Informacao-1.pdf>
2. Auditoria e Segurança de Sistemas de Informação - Repositório Institucional da Universidade Tecnológica Federal do Paraná (RIUT), https://repositorio.utfpr.edu.br/jspui/bitstream/1/23131/3/PB_ESPRC_II_2015_16.pdf
3. Introdução a Auditoria de TI - Fortinux.com, <https://fortinux.com/grc/introducao-a-auditoria-de-ti/>
4. Auditorias Internas X Externas De Ti E Suas Principais Diferenças - Stefanini Cyber, <https://stefaninicyber.com/auditoria-interna-x-externa-de-ti-e-suas-principais-diferencas/>
5. Auditoria Interna e Externa - CRCGO, <https://crcgo.org.br/wp-content/uploads/2022/12/Auditoria-Externa.pdf>
6. (PDF) Integrating COBIT 2019 and ISO/IEC 27001 for Strengthening IT Governance and Information Security - ResearchGate, https://www.researchgate.net/publication/398552151_Integrating_COBIT_2019_and_ISOIEC_27001_for_Strengthening_IT_Governance_and_Information_Security
7. Segurança no ciclo de vida de desenvolvimento de software - Red Hat, <https://www.redhat.com/pt-br/topics/security/software-development-lifecycle-security>
8. Proteja uma recomendação de ciclo de vida de desenvolvimento para Power Platform cargas de trabalho - Microsoft Learn, <https://learn.microsoft.com/pt-pt/power-platform/well-architected/security/security-development-lifecycle>
9. Aula 01 – Fraude e erro - Qconcursos,

- <https://vali.qconcursos.com/odin/topics/a608f18a-dce5-4e4d-aeed-711d2d813224.pdf>
10. Auditoria de Logs de TI: Acessos e Anomalias | Conheça e Aprenda - Eunerd,
<https://encontreunerd.com.br/artigos/ti-desorganizada/auditoria-de-logs-de-ti-acessos-e-anomalias>
 11. Auditoria externa e auditoria interna - Estratégia Concursos,
<https://www.estrategiaconcursos.com.br/blog/auditoria-externa-auditoria-interna/>
 12. AUDITORIA E CONFORMIDADE DE SEGURANÇA DA INFORMAÇÃO - TRF3,
https://www.trf3.jus.br/documentos/rget/seguranca/CLRI/GSIC345_Auditoria_Conformidade_Seguranca_Informacao.pdf
 13. AUDITORIA DE SISTEMAS - Ulife,
https://catalogcdns3.ulife.com.br/content-cli/CTI_AUDSIS_21/unidade_3/ebook/documentos/unidade3_auditoria-de-sistemas.pdf
 14. O que são e quais as diferenças entre auditoria interna e auditoria externa,
<https://www.hubscontabilidade.com.br/blog/artigo/diferencas-entre-auditoria-interna-e-externa/>
 15. Qual é a diferença entre ITGC e ITACs? : r/InternalAudit - Reddit,
https://www.reddit.com/r/InternalAudit/comments/18dgi0w/what_is_the_difference_between_itgc_and_itacs/?tl=pt-br
 16. A Auditoria Interna como ferramenta de melhoria dos controles internos de uma organização: Estudo de caso em uma empresa do segmento industrial do Rio de Janeiro - BDTD - UERJ,
https://www.btdtd.uerj.br:8443/bitstream/1/8173/1/Dissertacao_2009_Carlos_Renato_Trisciuzzi_Final.pdf
 17. Segurança e Auditoria de Sistemas | PDF - Scribd,
<https://pt.scribd.com/document/454185885/Livro-Seguranca-e-Auditoria-de-Sistemas-pdf>
 18. MANUAL DE AUDITORIA DE TECNOLOGIA DA INFORMAÇÃO - TCE-RO,
<https://tcero.tc.br/tribunal/legislacao/arquivos/Res-245-2017.pdf>
 19. Top ISMS Frameworks 2026: ISO 27001, COBIT & NIST - Sprinto,
<https://sprinto.com/blog/isms-frameworks/>
 20. ISO 27001 vs Cobit 2019 | Compliance Council,
<https://compliancecouncil.com.au/insights/iso-27001-vs-cobit-2019/>
 21. The IT Governance Trilogy: Understanding COBIT, ITIL, and ISO 27001 - Medium,
<https://medium.com/@cnh.zzt/the-it-governance-trilogy-understanding-cobit-itil-and-iso-27001-4449a917c7f3>
 22. Auditoria de Sistema de Informação - EduCAPES,
<https://educapes.capes.gov.br/bitstream/capes/1130784/2/Auditoria%20de%20Sistema%20de%20Informa%C3%A7%C3%A3o.pdf>
 23. Auditoria de governança de TI: entenda a importância - Escola Superior de Redes,
<https://esr.rnp.br/governanca-de-ti/auditoria-governanca-de-ti/>
 24. Padrões e Código de Ética para auditoria de SI - Aula 24,
<http://professor.ufop.br/sites/default/files/janniele/files/aula24.pdf>
 25. IT Auditor - ISACA,

- <https://www.isaca.org/career-center/career-journey/it-auditing/it-auditor>
26. O que é o ciclo de vida de desenvolvimento de software (SDLC)? - IBM,
<https://www.ibm.com/br-pt/think/topics/sdlc>
27. MPA - Trusted Partner Network,
https://www.ttpn.org/wp-content/uploads/2023/10/MPA-Content-Security-Best-Practices-v5.2_Aug30_2023-Release_PT-BR.xlsx
28. O que é o SDLC (ciclo de vida de desenvolvimento de software)? - AWS,
<https://aws.amazon.com/pt/what-is/sdlc/>
29. Anotações sobre Auditoria de Sistemas | Blog - João F F Nogueira,
<https://blog.joaonogueira.dev/posts/anotacoes-auditoria-de-sistemas/>
30. Ciclo de Vida de Desenvolvimento de Software | Microsoft Power Automate,
<https://www.microsoft.com/pt-pt/power-platform/topics/phases-of-the-software-development-lifecycle>
31. O que é o Ciclo de Vida de Desenvolvimento de Software (SDLC) - CrowdStrike,
<https://www.crowdstrike.com/pt-br/cybersecurity-101/exposure-management/software-development-lifecycle-sdlc/>
32. O que é o ciclo de vida de desenvolvimento de software (SDLC)? - OpenText,
<https://www.opentext.com/br/what-is/sdlc>
33. O papel da auditoria interna na detecção de fraudes com IA - Wolters Kluwer,
<https://www.wolterskluwer.com/pt-br/expert-insights/internal-audits-role-ai-fraud-detection>
34. SOC 2 e DevSecOps: Integrando a conformidade ao ciclo de vida,
<https://lazarusalliance.com/pt/SOC-2-e-DevSecOps%3A-integrando-a-conformidade-ao-ciclo-de-vida-do-desenvolvimento-de-software/>
35. Principais diferenças entre auditoria interna e externa - GlobalSuite Solutions,
<https://www.globalsuitesolutions.com/pt/principais-diferencas-entre-auditoria-interna-e-externa/>